

D486

Governance, Risk, and Compliance

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	_____	

Items

1.

An agency has categorized a new system and selected its control baseline. The project manager is a former auditor. What is the next RMF step?

- A. Assess, drawing on the PM's audit experience.
- B. Authorize the system.
- C. Categorize the system again.
- D. Implement the selected controls.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2. [TRANSFER — reversed stem / different variable]

Which RMF step results in a decision to accept residual risk and grant authority to operate?

- A. Assess
- B. Monitor
- C. Authorize
- D. Select

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3.

A system is rated Moderate for confidentiality, High for integrity, and Low for availability. It serves 1,500 users in a benefits office. What is its overall FIPS 199 category?

- A. Moderate
- B. Moderate, because most users only view data.
- C. Low
- D. High

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4. [TRANSFER — reversed stem / different variable]

A system's overall category is Moderate. Which set of C/I/A ratings could produce that?

- A. C Low, I Low, A Low
- B. Only Moderate for all three.
- C. C Moderate, I Low, A Low
- D. C High, I Low, A Low

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5.

A retailer classifies data as Public, Internal, or Confidential. Its marketing team built a spreadsheet of customer names with purchase histories. The spreadsheet has 14 tabs and colorful charts. How should it be classified and handled?

- A. Confidential; restrict access to those who need it and protect it with encryption.
- B. Internal.
- C. Public, since marketing made it.
- D. Based on its size and number of tabs.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6.

At a hospital, the IT team runs backups and applies access settings for the lab results database, while the lab director decides who may view results. The IT team has 25 staff. Who is the data owner?

- A. The lab director.
- B. The IT team.
- C. The CISO.
- D. Whoever holds admin rights, always.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7.

An agency selects the NIST SP 800-53 Moderate baseline for a system. One control cannot be implemented on legacy equipment; the equipment is 11 years old. What is the proper approach?

- A. Replace everything at once, since every control must always be met exactly as written.
- B. Drop the control without recording it.
- C. Switch the whole system to the Low baseline.
- D. Tailor: document the gap, apply a compensating control, and have the authorizing official accept it.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8.

A risk rated High before controls is rated Low after MFA and monitoring are added. The organization's risk appetite allows Medium. The risk was logged in the register by the IT director. What is the Low rating called, and what can management do?

- A. Residual risk; it must reach zero before acceptance.
- B. Residual risk; within appetite, so it can be formally accepted.
- C. Inherent risk; it must be reduced further.
- D. Residual risk; only the IT director may accept it because they logged it.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9. [TRANSFER — reversed stem / different variable]

After controls, a risk's residual rating is High, and the risk appetite is Low. What should management do?

- A. Accept it, since some controls exist.
- B. Raise the appetite to match the risk.
- C. Treat it further — add controls, transfer, or avoid — until it is within appetite.
- D. Relabel it as inherent risk.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10.

An audit finds 12 control weaknesses; 3 cannot be fixed for six months because of budget. The audit firm is based in another state. What is the proper next step for those 3?

- A. Record them in a POA&M with owners, milestones, dates, and interim controls.
- B. Wait for the next audit.
- C. Fix all 12 in 30 days, since any delay always voids authorization.
- D. Ask a local audit firm to redo the audit.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

An online store in Ohio accepts credit cards and has 3,000 customers, many of them in Canada. Which standard governs its handling of card data?

- A. GDPR, because customers live outside the U.S.
- B. PCI DSS
- C. HIPAA
- D. SOX

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12. [TRANSFER — reversed stem / different variable]

Auditors at a publicly traded company test controls over the systems that produce its financial statements. Which law drives this?

- A.** GLBA
- B.** SOX
- C.** PCI DSS
- D.** HIPAA

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	—	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer D Concept 1

An agency has categorized a new system and selected its control baseline. ~~The project manager is a former auditor.~~ What is the next RMF step?

Target word: next step **Decides:** Categorize and Select are done.

A	Camouflage	Controls must exist before they can be assessed.
B	Dropped element	Skips implementing and assessing.
C	Inverted operation	Categorization is already done.
D	Correct	Implementation follows selection.

2. Answer C Concept 1 • transfer

Which RMF step results in a decision to accept residual risk and grant authority to operate?

Target word: reverse: output to step **Decides:** A risk-acceptance decision by an official.

A	Adjacent category	Assessment produces findings, not the decision.
B	Confusion set	Monitoring continues after authorization.
C	Correct	The authorizing official accepts the risk and grants the ATO.
D	Inverted operation	An early step that chooses controls.

3. Answer D Concept 2

A system is rated Moderate for confidentiality, High for integrity, and Low for availability. ~~It serves 1,500 users in a benefits office.~~ What is its overall FIPS 199 category?

Target word: overall impact **Decides:** Highest of the three ratings.

A	Confusion set	Averages the ratings.
B	Camouflage	User count and behavior do not change the rule.
C	Inverted operation	Takes the lowest rating.
D	Correct	The high-water mark takes the highest rating, integrity.

4. Answer C Concept 2 • transfer

A system's overall category is Moderate. Which set of C/I/A ratings could produce that?

Target word: reverse: overall to inputs **Decides:** Highest rating is Moderate; none is High.

A	Dropped element	That would be Low overall.
B	Absolute language	Any mix whose highest is Moderate works.
C	Correct	The highest of the three is Moderate.
D	Confusion set	Averaging might suggest Moderate, but the high-water mark is High.

5. Answer A Concept 3

A retailer classifies data as Public, Internal, or Confidential. Its marketing team built a spreadsheet of customer names with purchase histories. ~~The spreadsheet has 14 tabs and colorful charts.~~ How should it be classified and handled?

Target word: classification and handling **Decides:** It contains customers' personal details.

A	Correct	Personal customer data is the most sensitive class here.
B	Adjacent category	Too low for personal purchase histories.
C	Inverted operation	The creator does not set sensitivity.
D	Camouflage	Format has nothing to do with sensitivity.

6. Answer A Concept 4

At a hospital, the IT team runs backups and applies access settings for the lab results database, while the lab director decides who may view results. ~~The IT team has 25 staff.~~ Who is the data owner?

Target word: owner vs. custodian **Decides:** The person who decides access is the owner.

A	Correct	The business leader accountable for the data decides access.
B	Confusion set	IT is the custodian that carries out the decisions.
C	Adjacent category	Sets security policy but does not own lab data.
D	Absolute language	Technical access does not make someone the owner.

7. Answer D Concept 5

An agency selects the NIST SP 800-53 Moderate baseline for a system. One control cannot be implemented on legacy equipment; ~~the equipment is 11 years old.~~ What is the proper approach?

Target word: handling a control that cannot be met **Decides:** Tailoring allows documented alternatives.

A	Absolute language	Frameworks allow tailoring and compensating controls.
B	Dropped element	Hides the gap from decision makers.
C	Inverted operation	Lowers protection everywhere to fix one control.
D	Correct	Tailoring keeps protection and accountability.

8. Answer B Concept 6

A risk rated High before controls is rated Low after MFA and monitoring are added. The organization's risk appetite allows Medium. ~~The risk was logged in the register by the IT director.~~ What is the Low rating called, and what can management do?

Target word: name and decision **Decides:** After-control rating is within appetite.

A	Absolute language	Zero risk is not a realistic requirement.
B	Correct	Residual risk at or below appetite may be accepted and monitored.
C	Inverted operation	Inherent risk is the rating before controls.
D	Camouflage	Who logged it does not set who accepts it.

9. Answer C Concept 6 • transfer

After controls, a risk's residual rating is High, and the risk appetite is Low. What should management do?

Target word: decision when above appetite **Decides:** Residual risk exceeds appetite.

A	Dropped element	Ignores that the result is still above appetite.
B	Adjacent category	Changes the yardstick instead of the risk.
C	Correct	Risk above appetite should not simply be accepted.
D	Inverted operation	The label does not change the exposure.

10. Answer A Concept 7

An audit finds 12 control weaknesses; 3 cannot be fixed for six months because of budget. ~~The audit firm is based in another state.~~ What is the proper next step for those 3?

Target word: remediation tracking **Decides:** Fixes are delayed.

A	Correct	Tracks the plan and limits risk in the meantime.
B	Dropped element	Leaves the risk unmanaged.
C	Absolute language	Documented, managed delays are normal.
D	Camouflage	Firm location does not change the findings.

11. Answer B Concept 8

An online store in Ohio accepts credit cards ~~and has 3,000 customers, many of them in Canada.~~ Which standard governs its handling of card data?

Target word: standard for card data **Decides:** Payment card data is involved.

A	Camouflage	GDPR is about EU residents; Canada is not the EU, and it is not a card-data standard.
B	Correct	Applies to anyone who stores, processes, or transmits card data.
C	Confusion set	Covers health information.
D	Adjacent category	Covers public-company financial reporting.

12. Answer B Concept 8 • transfer

Auditors at a publicly traded company test controls over the systems that produce its financial statements. Which law drives this?

Target word: reverse: activity to law **Decides:** Internal control over financial reporting.

A	Confusion set	Covers financial institutions' customer data privacy.
B	Correct	Requires public companies to maintain and test these controls.
C	Adjacent category	Covers card data, not financial statements.
D	Inverted operation	Covers health data, a different domain.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owled.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	5	
Wrong stem number	A figure copied from the prompt that is not the answer.	0	
Adjacent category	The right idea in the wrong bucket.	6	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	8	
Absolute language	Always, never, guarantee — where judgment applies.	5	
Confusion set	Every option is real; the test is exact role-matching.	6	
Camouflage	Answers a stem fact that was never the question.	6	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	Risk Management Framework steps	NIST RMF: Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor.	Jumping from selecting controls to authorization.	“What comes next” after a named step.
2	Security categorization (high-water mark)	FIPS 199 rates confidentiality, integrity, and availability; the system’s overall level is the highest of the three.	Averaging the three ratings.	Three impact ratings and “overall.”
3	Data classification	Classification follows the sensitivity of the content, and it drives handling: access limits, encryption, and retention.	Classifying by who made the file or its format.	A new data set containing personal or customer details.
4	Governance roles	The data owner (a business leader) decides who may access data; the custodian (often IT) carries out and maintains the controls.	Calling IT the owner because it runs the systems.	One party decides, another operates.
5	Baselines and tailoring	Start from a control baseline, then tailor with documented changes and compensating controls approved by the authorizing official.	Quietly dropping a control or lowering the whole baseline.	A control that cannot be implemented as written.
6	Inherent vs. residual risk	Inherent risk is before controls; residual risk is after. Residual risk within appetite may be accepted; above it must be treated further.	Requiring zero risk, or accepting risk above appetite.	Ratings before and after controls, plus an appetite.
7	Audit findings and remediation	Findings that cannot be fixed at once go on a plan of action and milestones (POA&M) with owners, dates, and interim controls.	Ignoring findings until the next audit.	“Cannot be fixed for six months.”
8	Matching regulations to data	PCI DSS = payment card data; HIPAA = health information; SOX = public-company financial reporting; GDPR = EU residents’ personal data; GLBA = financial institutions’ customer data.	Choosing a regulation by customer location or industry buzzwords.	The type of data or reporting involved.

Course scope (public description): Governance, Risk, and Compliance provides learners with advanced skills and knowledge to authorize and maintain information systems utilizing various risk management frameworks. The course focuses on the strategic and long-term alignment of an organization’s information security program to regulatory requirements and organizational policies. Course topics include compliance and regulatory requirements, data classification and prioritization, security and privacy controls, compliance audits and remediation, and risk management plans.